

Vulnerability Assessment Report

1st January 20XX

System Description

The server is a database server connected to the internal network.

Scope

This assessment focuses solely on the database server. It will evaluate potential risks to the server's data confidentiality, integrity, and availability.

Purpose

The database server is a highly valuable asset because it stores sensitive customer and employee data, which is essential for day-to-day business operations. Securing this data is critical to maintain customer trust, protect the organization's reputation, and ensure compliance with data privacy regulations. If the server were to be disabled or compromised, the business would suffer significant operational downtime, financial losses, and potential legal consequences due to a data breach. Conducting this vulnerability analysis is crucial to identify weaknesses before they can be exploited by malicious actors.

Risk Assessment

Threat source	Threat event	Likelihood	Severity	Risk
Insider Threat (Current or former employee)	Unauthorized access to sensitive customer or employee information stored on the database server.	2	3	6
Hackers / Cybercriminal Group	Performing a Denial of Service (DoS) attack or deploying ransomware, causing the database server to be unavailable.	2	3	6
Competitor / Corporate Espionage	Exfiltration (theft) of confidential business data from the server.	1	3	3

Approach

I selected these three specific threat sources—Insider Threats, Hackers, and Competitors—because they represent the most probable and damaging vectors for a database server holding sensitive information. Insider threats are significant because employees often already have some level of network access, increasing the likelihood of accidental or intentional data exposure. Hackers pose a severe threat due to the rising trend of ransomware and DoS attacks aimed at financial extortion. Finally, competitors present a risk to confidentiality through the potential exfiltration of proprietary data. I used a qualitative assessment to prioritize these high-level risks based on their potential to cause severe operational and reputational damage.

Remediation Strategy

To remediate and mitigate these identified risks, the organization must implement several layers of security controls. First, to mitigate insider threats and unauthorized access, we must strictly enforce the Principle of Least Privilege alongside Multi-Factor Authentication (MFA) for anyone accessing the database server. Second, to protect against exfiltration, data encryption (both at rest and in transit) must be implemented. Finally, to defend against hackers and DoS attacks, a Defense in Depth strategy should be adopted, including the configuration of firewalls, Intrusion Detection Systems (IDS), and routine security audits based on the AAA (Authentication, Authorization, Accounting) framework to monitor all database activity.